РЕГЛАМЕНТ АДМИНИСТРИРОВАНИЯ И ЭКСПЛУАТАЦИИ СИСТЕМ ОБЕСПЕЧЕНИЯ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ ОРГАНИЗАЦИИ «ВАСЬТЕХНОЛОДЖИС»

1. Общие положения.

1.1 Назначение документа.

Настоящий регламент определяет пошаговый порядок, сроки, зоны ответственности и конкретные процедуры по управлению и техническому обслуживанию средств защиты информации (СЗИ) в организации «ВАСЬТЕХНОЛОДЖИС». Документ является обязательным к исполнению ИТ-администраторами и сотрудниками Службы информационной безопасности.

1.2 Объекты администрирования.

Действия регламента распространяются на следующие системы:
- Сетевой шлюз / Межсетевой экран OPNsense.
- Серверные операционные системы Ubuntu Server.
- Систему мониторинга и реагирования Wazuh SIEM (Management, Agent).
- Автоматизированные рабочие места АРМ сотрудников.

2. Регламент управления учетными записями, паролями и SSH-ключами.

2.1 Порядок заведения учетных записей.

1. Заведение новой учетной записи на серверах Ubuntu, в OPNsense или Wazuh производится Администратором строго по официальной заявке от Службы безопасности.
2. Каждому сотруднику создается персональная учетная запись. Использование общих учетных записей категорически запрещено. Имя учетной записи должно позволять однозначно идентифицировать сотрудника.

2.2 Генерация и выдача паролей.

1. Все первичные пароли для критических систем и АРМ генерируются сотрудником Службы безопасности с использованием аппаратного или программного генератора псевдослучайных чисел.
2. Требования к паролю: длина не менее 12 символов, наличие заглавных и строчных букв, цифр и специальных знаков (@, #, $, и т.д.).
3. Передача пароля сотруднику осуществляется лично в руки в бумажном виде под подпись в журнале учета учетных данных. Передача паролей через мессенджеры, почту или по телефону запрещена.
4. При первом входе в систему сотрудник обязан изменить выданный первичный пароль на свой собственный, соответствующий тем же критериям сложности.

2.3 Управление SSH-ключами для Ubuntu Server.

1. Аутентификация администраторов на серверах Ubuntu по паролю запрещена на уровне конфигурации SSH-демона. Доступ разрешен только по ключам.
2. Сотрудник генерирует пару ключей (открытый/закрытый) локально на своем АРМ с использованием стойкого алгоритма (рекомендуется Ed25519 или RSA 4096).
3. Открытый ключ (.pub) передается в Службу безопасности для верификации и последующего добавления Администратором в файл ~/.ssh/authorized_keys на целевом сервере.
4. Закрытый (приватный) ключ является строго конфиденциальным, должен храниться на АРМ сотрудника в зашифрованном виде (защищен Passphrase) и не подлежит передаче кому-либо, включая Службу безопасности.

2.4 Блокировка и отзыв прав.
1. При увольнении сотрудника или изменении его должностных обязанностей Служба безопасности немедленно направляет Администратору требование о блокировке учетной записи.
2. Администратор производит деактивацию учетной записи в системах и удаляет открытый SSH-ключ сотрудника со всех серверов. Удаление самой учетной записи откладывается на срок, согласованный с руководством, для сохранения результатов работы.

3. Регламент технического обслуживания и контроля межсетевого экрана OPNsense.

3.1 Периодичность и порядок обновлений.
1. Мониторинг обновлений: Администратор безопасности обязан еженедельно проверять наличие обновлений прошивки (Firmware) и базовой операционной системы HardenedBSD через веб интерфейс OPNsense (System → Firmware → Updates).
2. Патчи безопасности: при выходе критических обновлений безопасности, закрывающих уязвимости удаленного выполнения кода (RCE) или обхода аутентификации, установка обновлений производится в течение 24 часов с момента релиза.
3. Регламентное окно: плановые обновления OPNsense проводятся строго во вненерабочее время, так как процесс может потребовать перезагрузки шлюза и вызвать кратковременный простой сети.

3.2 Резервное копирование конфигурации OPNsense.
1. Автоматический бэкап при изменениях: Перед внесением любого изменения в правила файрвола, NAT, настройки VLAN или VPN, Администратор обязан сделать резервную копию текущей конфигурации в формате .xml (System → Configuration → Backups)
2. Экспорт и хранение: скачанный файл конфигурации .xml должен быть зашифрован и перенесен на изолированный бэкап-сервер. Запрещается хранить бэкапы OPNsense на рабочих станциях в незашифрованном виде.

3. Глубина архива: организация сохраняет последние 10 версий конфигурационных файлов OPNsense. Каждому файлу бэкапа присваивается имя формата: OPNsense_backup_YYYYMMDD_ИнициалыАдминистратора.xml.

3.3 Аудит правил фильтрации трафика.
1. Еженедельная проверка: Администратор каждую пятницу проводит анализ заблокированного трафика в меню (Firewall → Log files → Live View). Особое внимание уделяется кратным заблокированным запросам из зоны LAN в зону Management.
2. Ежемесячная ревизия правил: раз в месяц Служба безопасности совместно с Администратором проводит аудит всей таблицы правил (Firewall Rules). Все временные правила (созданные для тестов или отладки) должны быть деактивированы и удалены.
3. Принцип жесткого логирования: на всех запрещающих правилах, а также на критических разрешающих правилах (Wazuh-агентов к серверу) в OPNsense должен быть включен чекбокс Log packet. Эти логи в реальном времени должны транслироваться на сервер Wazuh по протоколу Syslog/TLS.

4. Регламент технического обслуживания и контроля операционных систем Ubuntu Server.

4.1 Управление обновлениями ОС и патчинг.
1. Автоматические обновления безопасности: на всех серверах Ubuntu Server должен быть установлен и активен пакет unattended-upgrades. Администратор обязан сконфигурировать его на ежедневную автоматическую установку пакетов из репозиториев ubuntu-${distro}-security.
2. Перезагрузка после патчинга: если установленные обновления безопасности требуют перезагрузки ядра, Администратор выполняет перезагрузку сервера строго в регламентное технологическое окно, предварительно убедившись в наличии актуальных бэкапов.
3. Плановое обновление ПО: обновление общесистемного и прикладного ПО производится вручную Администратором один раз в месяц после тестирования обновлений на тестовом стенде.

4.2 Ежедневный контроль состояния системных узлов.
1. Проверка дискового пространства: Администратор ежедневно контролирует утилизацию дисков (команда df -h в режиме реального времени). При заполнении любого раздела (особенно /var/log) более чем на 80%, Администратор обязан выяснить причину и очистить место или расширить накопитель.
2. Контроль запущенных служб: не реже одного раза в неделю проводится проверка статуса критических демонов (Wazuh Agent, SSHD, Docker/Nginx) с помощью команды systemctl status или через панель Wazuh.

4.3 Аудит безопасности и логирования.

1. Аудит прав sudo: раз в неделю Администратор производит выгрузку и анализ всех событий использования команды sudo (из журнала). Любой вызов команд через sudo, не связанный с регламентными работами, подлежит расследованию Службой безопасности.
2. Проверка целостности пакетов: раз в месяц выполняется проверка целостности установленных бинарных файлов и утилит с помощью встроенных средств менеджера пакетов. Изменения в системных путях (/bin) отслеживаются модулем FIM системы Wazuh в реальном времени.

5. Регламент мониторинга, аудита и реагирования Wazuh SIEM.

5.1 Ежедневный мониторинг и классификация алертов.
1. Регулярность контроля: Администратор безопасности обязан проверять веб-интерфейс Wazuh Dashboard не менее трех раз в день.
2. Обработка критических событий: при возникновении алертов наивысшего уровня опасности, время реакции Администратора составляет не более 15 минут с момента фиксации события системой.
3. Обработка событий среднего уровня: алерты среднего уровня разбираются Администратором в течение рабочего дня.

5.2 Аудит модуля контроля целостности файлов (FIM).
1. Проверка изменений: Администратор ежедневно отслеживает вкладку File Integrity Monitoring в Wazuh.
2. Легитимация изменений: При обнаружении изменений в критических конфигурационных файлах, Администратор обязан сверить время изменения с журналом проведения плановых технических работ. Любое несанкционированное изменение файла приравнивается к инциденту информационной безопасности.

5.3 Контроль работы подсистемы Active Response.
1. Анализ заблокированных IP: раз в сутки Администратор проверяет журнал срабатываний Active Response. Выявляются IP-адреса, которые были заблокированы локальным файрволом (UFW) за брутфорс SSH или сканирование.
2. Ведение черных списков: если один и тот же внешний IP-адрес блокируется автоматикой Wazuh более трех раз за неделю, Администратор обязан внести данный IP-адрес в постоянное запрещающее правило на межсетевом экране OPNsense на уровне периметра.

5.4 Сроки хранения логов и грубина архива.
1. Отображение в панели: логи индексы алертов хранятся в «горячем» режиме (с возможностью быстрого поиска в Elasticsearch/OpenSearch) не менее 30 дней.
2. Холодный архив: архивы сырых логов сжимаются и перемещаются на изолированный бэкап-сервер. Срок хранения холодного архива составляет 1 год.

6. Регламент резервного копирования и тестового восстановления.

6.1 Расписание и объекты резервного копирования.
Резервное копирование выполняется в автоматическом режиме во внерабочее время согласно следующему графику:
- Конфигурация межсетевого экрана OPNsense (XML): выгружается автоматически после каждого изменения настроек, а также еженедельно по воскресеньям.
- Базы данных и конфигурации серверов Ubuntu: полный бэкап — один раз в неделю. Дифференциальный или инкрементальный бэкап (изменения) — ежедневно в рабочие дни.
- Конфигурации и базы алертов Wazuh SIEM: еженедельно.

6.2 Техническая реализация и изоляция бэкапов.
1. Принцип Pull: инициатором сессии резервного копирования всегда выступает выделенный изолированный бэкап-сервер. Запрещается отправка бэкапов (Push-модель) с целевых серверов Ubuntu или OPNsense на бэкап-хост.
2. Алгоритм сессии: в назначенное время бэкап-сервер подключается по защищенному каналу (SSH/rsync по ключам) к целевому узлу, скачивает необходимые данные и немедленно закрывает сессию. На целевых серверах права учетной записи, под которой происходит подключение, должны быть ограничены только чтением необходимых директорий.
3. Сетевая изоляция: на межсетевом экране OPNsense настраиваются правила, полностью блокирующие любой входящий трафик из зон LAN и DMZ в зону бэкап-сервера.

6.3 Шифрование и хранение резервных копий.
1. Обязательное шифрование: все файлы бэкапов, содержащие коммерческую тайну, исходный код или персональные данные, подлежат обязательному шифрованию на стороне бэкап-сервера сразу после завершения копирования с использованием стойких алгоритмов (например, GPG или AES-256).
2. Правило 3-2-1: бэкап-сервер хранит рабочие копии на локальном RAID-массиве (2 разных типа носителей). Дополнительно, один раз в неделю наиболее критичные зашифрованные архивы выгружаются на отчуждаемый носитель или в изолированное облачное хранилище.
3. Глубина хранения: устанавливается обязательный срок хранения ежедневных бэкапов — 14д, еженедельных — 60д.

6.4 Регламент тестового восстановления.
1. Ежемесячная проверка: каждое второе воскресенье месяца Администратор совместно со Службой безопасности обязан проводить тестовое восстановление ключевых систем (хотя бы одного сервера Ubuntu и конфигурации OPNsense) из архива бэкапов в изолированную тестовую среду.

2. Критерий успешности: тест считается пройденным успешно, если операционная система полностью загрузилась, службы (Wazuh Ageht) запустились без ошибок, а целостность тестовых данных не нарушена.
3. Журналирование: результаты проверки заносятся в «Журнал контроля резервного копирования» с указанием даты, времени восстановления и подписью ответственного лица. При обнаружении поврежденных архивов немедленно инициируется процедура создания нового полного бэкапа.